



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



ChocoPoC Trojanized Exploit Repositories Target Vulnerability Researchers

Threat Report

Classification	TLP:CLEAR
Published	2026-07-07
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Report

TLP:CLEAR | Lost Boys Cyber | ChocoPoC Trojanized Exploit Repositories Target Vulnerability Researchers - Threat Report

Published: 2026-07-07 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review & Confidence
4. Threat Activity Overview
5. Affected Products, Sectors, and Exposure
6. Tactics, Techniques, and Procedures
7. Detection Engineering
 - 7.1. Detection Summary
 - 7.2. Sigma / Detection Content
 - 7.3. Microsoft Defender Hunting Query
8. Threat Hunting
 - 8.1. Hunt Hypothesis
9. Risk Assessment
10. Recommended Actions
11. References

ChocoPoC Trojanized Exploit Repositories Target Vulnerability Researchers

1. Executive Summary

Lost Boys Cyber selected ****ChocoPoC Trojanized Exploit Repositories Target Vulnerability Researchers**** for the 2026-07-07 daily intelligence production run because it presents near-term defender value for vulnerability researchers, red teams, security engineering teams, and SOCs. The core issue is fake proof-of-concept repositories and malicious Python dependencies delivering ChocoPoC RAT. This report converts current public reporting into an operational brief with source confidence, exposure analysis, detection logic, hunting queries, and prioritized actions.

The report intentionally avoids unverified atomic IOCs when public sources do not provide them. Defenders should use the included behavioral hunts as triage pivots and update local detections if primary-source IOCs become available.

2. Intelligence Requirements

Question	Current Answer	Confidence
What is the core activity?	fake proof-of-concept repositories and malicious Python dependencies delivering ChocoPoC RAT.	medium-high
Who should prioritize it?	vulnerability researchers, red teams, security engineering teams, and SOCs.	Medium-High
What exposure is most relevant?	analyst workstations, CI runners, exploit-validation labs, and research sandboxes that clone and execute public PoC code.	Medium
What should defenders do today?	Validate exposure, patch or harden affected systems, run the included hunts, and preserve evidence for any matches.	High

3. Source Review & Confidence

Source	Contribution	Confidence
YesWeHack: ChocoPoCs trojanised exploits	Primary co-research describing malicious PoC repositories targeting vulnerability researchers.	High
Sekoia: ChocoPoC campaign analysis	Primary co-research linking multiple trojanized PoCs and dependency packages to a single actor assessment.	Medium
BleepingComputer: ChocoPoC malware targets researchers	Independent coverage noting malicious PyPI dependencies rather than malware embedded directly in visible exploit files.	Medium

Source depth was sufficient for an analyst-facing report. Claims are framed as reported when based on vendor or media reporting rather than direct Lost Boys Cyber telemetry.

4. Threat Activity Overview

ChocoPoC Trojanized Exploit Repositories Target Vulnerability Researchers should be treated as an operational prioritization item rather than a headline-only news event. The primary defensive concern is that the reported activity can translate quickly

into credential theft, remote code execution, unauthorized remote access, malware staging, or ransomware preparation depending on local exposure.

5. Affected Products, Sectors, and Exposure

Exposure Area	Why It Matters	Defender Check
analyst workstations, CI runners, exploit-validation labs, and research sandboxes that clone and execute public PoC code	Primary route by which this intelligence becomes locally relevant.	Confirm inventory ownership, patch/hardening state, and exposed services.
Identity and privileged access	Most modern intrusions become severe once valid credentials or privileged sessions are available.	Review MFA, impossible travel, new devices, and admin-session anomalies.
Endpoint and server telemetry	Required to connect initial access to execution, staging, exfiltration, or impact.	Validate EDR coverage and command-line logging on high-value assets.
Third-party and supply-chain dependencies	Shared tooling or service providers can introduce indirect exposure.	Review vendor access, integration tokens, and emergency contacts.

6. Tactics, Techniques, and Procedures

Phase	ATT&CK Mapping	Relevance
Initial Access	T1566 Phishing / T1195 Supply Chain Compromise / T1078 Valid Accounts	Most plausible route based on the selected reporting and exposure class.
Execution	T1059 Command and Scripting Interpreter	Common follow-on for loader, exploit, or hands-on-keyboard activity.
Credential Access	T1555 Credentials from Password Stores / T1003 OS Credential Dumping	Relevant when malware, VPN abuse, or researcher/developer compromise is plausible.
Command and Control	T1071 Application Layer Protocol / T1102 Web Service	Expected where commodity malware, loaders, or remote-access tooling appears.
Impact	T1486 Data Encrypted for Impact / T1490 Inhibit System Recovery	Relevant for ransomware-linked or extortion-enabled scenarios.

7. Detection Engineering

7.1. Detection Summary

Signal	Telemetry Source	Analytic Goal
Report keywords in command line, alert title, repository/package names, or ticket notes	EDR/SIEM/SOAR	Fast triage pivot for named activity and related internal chatter.
Scripting tools launched from unusual parent processes or developer/research directories	EDR	Identify execution after exploit-code cloning, phishing, or administrative abuse.
New privileged or VPN session followed by suspicious process/network activity	IAM + EDR + VPN	Detect identity-to-endpoint intrusion chaining.

Archive creation or outbound transfer after suspicious execution	EDR + proxy/network	Detect staging before exfiltration or extortion.
--	---------------------	--

7.2. Sigma / Detection Content

```

title: Lost Boys Cyber - ChocoPoC Trojanized Exploit Repositories Target Vulnerability Researchers
id: lbc-chocopoc-trojanized-exploit-repositories-target-
status: experimental
description: Behavioral detection for the daily intelligence item ChocoPoC Trojanized Exploit
Repositories Target Vulnerability Researchers.
logsource:
  product: windows
  category: process_creation
detection:
  selection_keywords:
    CommandLine|contains:
      - 'chocopoc'
      - 'credential'
      - 'ransomware'
      - 'loader'
  selection_tools:
    Image|endswith:
      - '\powershell.exe'
      - '\cmd.exe'
      - '\rundll32.exe'
      - '\wscript.exe'
      - '\python.exe'
      - '\node.exe'
  condition: selection_keywords or selection_tools
falsepositives:
  - Security testing, malware analysis, administrator troubleshooting, or legitimate developer activity
level: medium

```

7.3. Microsoft Defender Hunting Query

```

let keywords = dynamic(['chocopoc', 'fake', 'credential', 'ransomware', 'loader']);
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any (keywords)
  or FileName in~
('powershell.exe','cmd.exe','rundll32.exe','wscript.exe','cscript.exe','python.exe','node.exe')
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Hosts=dcount(DeviceName),
Examples=make_set(ProcessCommandLine, 5) by FileName, InitiatingProcessFileName
| order by LastSeen desc

```

8. Threat Hunting

8.1. Hunt Hypothesis

If this activity affected the environment, defenders should observe a chain connecting the reported exposure class to suspicious execution, outbound network activity, credential access, archive creation, or ransomware/extortion preparation.

```

let keywords = dynamic(['chocopoc', 'fake', 'credential', 'ransomware', 'loader']);
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has_any (keywords) or InitiatingProcessCommandLine has_any (keywords)
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, RemoteUrl,
RemoteIP, RemotePort
| union (
  DeviceFileEvents
  | where Timestamp > ago(30d)
  | where FileName endswith '.7z' or FileName endswith '.rar' or FileName endswith '.zip' or
FolderPath has_any (keywords)
  | project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine,
RemoteUrl='', RemoteIP='', RemotePort=int(null)
)

```

9. Risk Assessment

Dimension	Assessment
Likelihood	Medium to High where the exposure class exists and logging/patching is incomplete.
Impact	Credential theft, unauthorized access, malware execution, data exposure, operational disruption, or ransomware depending on local exposure.
Confidence	medium-high overall; higher for primary-source claims and lower for local-environment applicability.

10. Recommended Actions

Priority	Owner	Action
Critical	SOC	Run the included hunts and correlate any hits with identity, VPN, proxy, and ticket context.
High	IT / Platform Owners	Patch, isolate, or harden affected systems and validate internet exposure.
High	IAM	Review MFA enforcement, privileged access, new devices, and recent session anomalies.
Medium	IR	Confirm containment playbooks, backup health, and evidence preservation for matching systems.
Medium	Threat Intel	Track source updates and enrich detections if atomic IOCs or vendor rules are released.

11. References

- [1] YesWeHack: ChocoPoCs trojanised exploits. <https://www.yeswehack.com/news/chocopocs-vulnerability-researchers-trojanised-exploits>
- [2] Sekoia: ChocoPoC campaign analysis. <https://www.sekoia.com/blog/dont-eat-the-chocopocs-how-vulnerability-researchers-were-repeatedly-targeted-by-trojanised-exploits>
- [3] BleepingComputer: ChocoPoC malware targets researchers. <https://www.bleepingcomputer.com/news/security/new-chocopoc-malware-targets-researchers-via-trojanized-poc-exploits/>